CRA Incident Simulation

Çıktı: Incident Workflow

Ad Soyad	Grup	Tarih

Senaryo: Saat **10:15**. PaketPro'nun servis hesabına gece 03:00'te tanınmayan bir konumdan girilmiş. PLC konfigürasyonu değişmiş olabilir; **ışık perdesi parametreleri henüz doğrulanmadı**. Makine çalışıyor. Vardiya sorumlusu sizsiniz.

Kavram: Bir olayda en değerli iki şey **zaman** ve **kanıt**tır. CRA'nın 24s / 72s / 14 gün yükümlülükleri, iyi bir müdahale akışının doğal kilometre taşlarıdır — ezber değil.

Görev — zaman çizgisini doldurun

1. **10:15 — ilk 15 dk:** Kimi ararsınız? İlk üç eyleminiz?

   İlk olarak OT Güvenlik / IT Olay Müdahale Ekibini ve Hat Emniyet Sorumlusunu ararım. İlk üç eylemim: Çene ve bıçak bölgelerindeki fiziksel insan temasını derhal durdurup operatörleri hattan uzaklaştırmak, makinenin uzak ağ/VPN bağlantısını fiziksel olarak kesmek ve kesinlikle reset atmadan mevcut RAM/çalışma durumunu dondurmaktır.

2. **İlk 2 saat:** Emniyet güvende mi — nasıl doğrularsınız? Hangi kanıt korunur? Hangi hesap kapatılır?

   Emniyeti, ışık perdesi ve acil durdurma hatlarının fiziksel tetikleme testlerini yaparak ve Safety PLC'nin yazılım sağlama toplamı (checksum) değerini bilinen güvenli hash ile karşılaştırarak doğrularım. Yetkisiz giriş yapılan servis hesabını derhal kapatır; PLC/HMI uç birim bellek dökümlerini, ağ anahtarı (switch) pcap paketlerini ve Jump Server erişim oturum kayıtlarını adli bilişim için güvenceye alırım.

3. **24 saat — CRA erken uyarı:** Hangi bilgi hazır olmalı?

   İhlalin saat 03:00'te tanınmayan bir IP üzerinden servis hesabı istismarıyla başladığı, olayın termoform paketleme makinesinin PLC/emniyet parametrelerini hedef almış olabileceği ve insan emniyetini riske atmamak adına alınan acil izolasyon tedbirleri hazır olmalıdır.

4. **72 saat — CRA bildirim:** Kök neden, etki, önlem — kim ne yapıyor?

   Kök neden analisti giriş yapılan dış IP'yi ve zafiyetli servis kapısını tespit ederken, otomasyon mühendisi değiştirilen PLC konfigürasyonunu raporlar; yönetim ise etkilenen hat durumunu, kapatılan zafiyetleri ve devreye alınan MFA zorunluluğunu içeren resmi teknik raporu yetkili makamlara sunar.

5. **14 gün — son rapor:** Hangi loglar/kayıtlar korunmuş olmalı?

   Saldırı anına ait güvenlik duvarı trafik logları, Jump Server tam oturum video/tuş vuruşu kayıtları, PLC konfigürasyon diff/karşılaştırma raporları, olay anındaki HMI alarm geçmişi ve adli analizi kanıtlayan zaman damgalı adli imajlar (adli kopyalar) eksiksiz korunmuş olmalıdır.

En sık hata: "Resetleyip devam edelim" — o düğme, kanıtı sonsuza dek siler. Önce emniyet, hemen sonra kanıt.

Bu föyün çıktısı **Incident Workflow** → Evidence Pack **EP 13 Incident Response** başlığına oturur.